

7. Linux Capabilities

Linux Capabilities adalah mekanisme yang memecah hak akses root menjadi kemampuan-kemampuan kecil yang dapat diberikan ke program tertentu.

Tujuannya:

Tidak perlu memberikan root penuh

↓

Hanya memberikan kemampuan yang diperlukan

Contoh:

Program A hanya perlu membuka port <1024

Program B hanya perlu mengubah network interface

Tidak harus dijalankan sebagai root.

Mengapa Penting di Boot2Root?

Banyak peserta:

Cek sudo

Cek SUID

Tidak menemukan apa-apa

↓

Menyerah

Padahal terkadang jalurnya ada di Capabilities.

Cara Melihat Capabilities

Perintah utama:

```
getcap -r / 2>/dev/null
```

Contoh hasil:

```
/usr/bin/python3 = cap_setuid+ep
```

```
/usr/bin/ping = cap_net_raw+ep
```

```
/usr/bin/tar = cap_dac_read_search+ep
```

Cara Membaca Hasil

Contoh:

```
/usr/bin/python3 = cap_setuid+ep
```

Artinya:

```
python3
```

memiliki capability tertentu
yang perlu dianalisis lebih lanjut.

Capability yang Sering Muncul

cap_net_raw

Contoh:

/usr/bin/ping

Digunakan untuk operasi jaringan tingkat rendah.

Biasanya normal.

cap_net_bind_service

Memungkinkan program membuka port:

1 - 1023

Biasanya normal untuk web server.

cap_dac_read_search

Mengizinkan bypass sebagian kontrol pembacaan file.

Jika diberikan ke program yang tidak semestinya, perlu ditinjau.

cap_setuid

Sangat menarik.

Capability ini berkaitan dengan identitas user proses dan harus diperiksa dengan hati-hati.

cap_setgid

Mirip dengan:

cap_setuid

tetapi untuk group.

Enumerasi Capability

Ketika menemukan:

```
getcap -r / 2>/dev/null
```

Buat daftar:

Program
Capability
Apakah normal?
Apakah custom?

Prioritas Analisis

Program Custom

Contoh:

```
/opt/backup  
/usr/local/bin/admin  
/home/dev/tool
```

Lebih menarik daripada binary sistem standar.

Program Interpreter

Contoh:

```
python  
perl  
ruby  
php
```

Jika memiliki capability tambahan, perlu dianalisis karena interpreter dapat menjalankan kode arbitrer.

Cek Binary

Misal ditemukan:

```
/opt/admin
```

Lihat:

```
file /opt/admin
```

Lalu:

strings /opt/admin

Cari:

password
backup
root
system

atau petunjuk lain.

Capability vs SUID

SUID:

Program berjalan sebagai root

Capabilities:

Program memiliki kemampuan tertentu

Capabilities sering lebih tersembunyi.

Checklist Enumerasi

Jalankan:

getcap -r / 2>/dev/null

Kemudian untuk setiap hasil:

1. Binary standar atau custom?
2. Capability apa?
3. Apakah capability diperlukan?
4. Siapa pemilik file?
5. Permission file?

Studi Kasus CTF

Misal:

sudo -l

Tidak ada hasil.

Misal:

find / -perm -4000

Tidak ada temuan menarik.

Namun:

```
getcap -r / 2>/dev/null
```

Menghasilkan:

```
/opt/admin = cap_setuid+ep
```

Sekarang fokus berpindah ke:

Apa fungsi /opt/admin?

Siapa pemiliknya?

Apa yang dilakukan?

Banyak peserta tidak pernah memeriksa capabilities dan melewati jalur privilege escalation.

Urutan Enumerasi Lengkap Setelah Mendapat Shell

Saya biasanya mengikuti urutan berikut:

1. whoami
2. id
3. sudo -l
4. find / -perm -4000
5. getcap -r / 2>/dev/null
6. cat /etc/crontab
7. ls /home
8. env
9. ps aux
10. ss -tulpn
11. LinPEAS

Jika semua jalur privilege escalation sudah dipelajari, langkah berikutnya dalam kurikulum Boot2Root adalah berpindah ke Web Exploitation, dimulai dari SQL Injection Dasar (cara mengenali dan menguji parameter yang rentan dalam aplikasi CTF/lab). Saya bisa menjelaskan konsep SQL Injection, indikator kerentanan, dan metode analisisnya tanpa memberikan payload serangan operasional.